

Oversight of Esbjerg Municipality

Date: 22-12-2023

Decision

Public Authorities

Criticism

Supervision / Self-Operation Case

Processing Security

Fundamental Principles

Risk Assessment and Impact Analysis

The Data Protection Agency has made decisions in five oversight cases regarding the processing security in AULA. The Data Protection Agency found reason to issue orders for the preparation of impact analyses in two of the cases. Additionally, the oversight has expressed criticism and serious criticism in the cases.

Journal Number: 2023-423-0006.

Summary

The Data Protection Agency initiated oversight in the autumn of 2021 concerning the processing of personal data in the IT system AULA by a total of six selected municipalities. The oversight focused on compliance with the data protection regulation's rules regarding processing security and impact analysis.

"When schools/childcare institutions and parents communicate via AULA, sensitive and confidential information about children is often included. It is therefore important that municipalities take good care of the information in AULA. According to the data protection regulation, children have a right to special protection," says Signe Vestergård, special consultant at the Data Protection Agency.

The Data Protection Agency has now made decisions in all cases except one, as this case contains some additional elements.

The oversight is a continuation of the Data Protection Agency's previous oversight of Kombit A/S (hereinafter KOMBIT) in December 2019. During the relevant oversight visit, the Data Protection Agency found that KOMBIT could not be considered a data controller for AULA under Article 4, No. 7 of the data protection regulation. At the oversight meeting, the Data Protection Agency informed KOMBIT that KOMBIT should ensure that all municipalities were informed of their data responsibilities and that KOMBIT should provide all necessary materials and information to the municipalities in this regard.

The Data Protection Agency finds that the oversight cases raise some general data protection legal issues across the municipalities, which can be better handled collectively rather than separately by the individual municipalities. Therefore, the Data Protection Agency has chosen to inform the Danish Municipalities Association (KL), the Agency for IT and Learning, and Kombit A/S (hereinafter KOMBIT) about the oversight's decisions in these cases. At the same time, the Data Protection Agency has formulated some recommendations for further work on processing security in AULA.

Furthermore, the Data Protection Agency will provide the same recommendations in a letter to all municipalities in the country, where the oversight will also inform them about the decisions. The purpose of the communication to the municipalities is to encourage them to consider whether the material gives rise to (further) assessments, etc., or to ensure the implementation of additional security measures concerning their processing of personal data in AULA.

Impact Analysis

Although the five municipalities use the same technical solution (AULA) for the same processing activities, they have had a markedly different approach to the issue of impact analyses.

All five municipalities have received criticism or serious criticism in the part of the cases concerning impact analysis. Two of the municipalities have received serious criticism for not having prepared an impact analysis. The Data Protection Agency has also issued these two municipalities an order to prepare an impact analysis within three months.

The other three municipalities have prepared impact analyses. The Data Protection Agency has reviewed them and assessed that none of them meet all the minimum requirements for an impact

analysis.

In addition, the Data Protection Agency has examined the timing of the preparation of the impact analyses and taken into account that there has been uncertainty regarding the data responsibility for the processing of personal data in AULA. The municipalities and KOMBIT have thus been under the impression that the data responsibility for the processing of personal data and the responsibility for conducting risk assessments and impact analyses lay with KOMBIT. However, the Data Protection Agency concluded during the oversight visit to KOMBIT in December 2019 that KOMBIT cannot be considered a data controller.

All three municipalities prepared their impact analyses long after clarity regarding the data responsibility for the processing of personal data in AULA had been established. Two of the municipalities even prepared their impact analyses only after the oversight had requested the material in connection with the initiation of the oversight, which is why the Data Protection Agency has expressed serious criticism towards these two municipalities. The Data Protection Agency has expressed criticism towards the third municipality.

Risk Assessment

All five municipalities have also received criticism or serious criticism concerning the part of the cases that deal with the municipalities' risk assessment. The criticism pertains to the documentation requirement to demonstrate that they have identified and mitigated the risks that the processing of personal data in AULA poses for the individuals concerned, ensuring an appropriate level of security. Additionally, the criticism concerns the lack of identification and implementation of relevant measures to ensure an appropriate level of security.

The Data Protection Agency has expressed serious criticism of two of the municipalities for not having submitted actual risk assessments. One municipality stated in January 2023 that they had not yet completed the preliminary work to identify relevant measures that could be implemented to mitigate the identified high risks.

the supervision of personal data processing in AULA. The other municipality referred to a number of appendices as documentation for what mitigating measures the municipality had taken to reduce the risk for the data subjects. The other three municipalities have submitted risk assessments. However, the Data Protection Agency has expressed criticism towards these municipalities, as they have not sufficiently demonstrated that they have ensured an appropriate level of security.

Several municipalities have submitted material from KOMBIT, where a number of high risks associated with the use of AULA have been identified. The municipalities have responded differently to the material. Some municipalities have stated that they have adopted KOMBIT's risk assessment and have based their descriptions of the measures they have implemented to reduce these risks on it. One municipality states that they have reviewed the material from KOMBIT but concluded that it could not be immediately used as a basis for actual risk assessments. Other municipalities have conducted their own assessments, where some of the risks they have identified are assessed to pose a lower risk than what is indicated in KOMBIT's material – however, without sufficiently documenting the basis for this assessment.

Risk of Misdelivery in AULA

The Data Protection Agency has found that a large portion of the reports of breaches of personal data security in AULA, which the agency receives, concern the misdelivery of personal data to one or more incorrect recipients in AULA. This is also a risk that several municipalities have identified in their risk assessments. Several of the municipalities have implemented organizational measures aimed at informing users about this risk when sending messages via AULA. Additionally, one of the municipalities has also implemented a change request in AULA that allows for the deletion and editing of sent content in messages.

Despite these measures, the Data Protection Agency continues to receive a number of reports of breaches from municipalities concerning misdelivery in AULA. It is generally the Data Protection Agency's view that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should investigate whether it is possible to

implement one or more technical measures to reduce the risk of misdelivery. They should also explore the possibilities of designing the messaging function in a way that minimizes such risk.

In a letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has recommended that KOMBIT, together with the responsible municipalities, conduct such an investigation. This recommendation will also be reiterated in a letter to all municipalities in the country.

Joint Impact Assessment and Code of Conduct

It is the Data Protection Agency's view that municipalities have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA. This is based on the fact that the municipalities use the same type of system for the same processing activities of the same type of personal data, and that the municipalities' processing activities involve similar high risks. Furthermore, the system is provided by the same supplier.

In the letter to KL, KOMBIT, and the Agency for IT and Learning, the Data Protection Agency has therefore encouraged consideration across municipalities, and possibly in collaboration with KL and KOMBIT, to prepare a joint impact assessment regarding the municipalities' processing of personal data in AULA.

The Data Protection Agency has additionally recommended that KL, in collaboration with the municipalities and possibly KOMBIT, consider the possibility of developing a code of conduct in accordance with Article 40 of the General Data Protection Regulation regarding the municipalities' processing of personal data in AULA. The Data Protection Agency has noted that this consideration may also be relevant for other processing activities in the municipalities, where they use the same system for the same processing activities of the same types of personal data, which involve similar high risks.

A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This could, for example, involve establishing procedures that must be followed for a specific processing activity. A code of conduct would therefore be a useful tool to help comply with data protection rules for the authorities that have subscribed to the code.

Although it facilitates compliance with the rules, it does not exempt the individual data controller from the obligations and tasks that fall upon them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processes – for example, by using a system for other purposes.

"It is a large and resource-intensive task for individual municipalities to conduct risk assessments and impact assessments that ensure the appropriate security measures. But it is necessary. AULA is a tool used in all municipalities for the same processing activities of the same type of personal data. We therefore encourage the municipalities – possibly in collaboration with KL and KOMBIT – to come together and ensure that citizens' information in AULA is adequately protected," says Signe Vestergård, special consultant at the Data Protection Agency.

1. Written supervision of Esbjerg Municipality regarding the IT system AULA

Esbjerg Municipality is among the municipalities that the Data Protection Agency selected for supervision in the autumn of 2021.

supervision under the General Data Protection Regulation[1] and the Data Protection Act[2].

The Data Protection Authority's supervision is a written oversight with a particular focus on the technical and organizational security measures that have been observed to meet the requirement for an appropriate level of security for the processing activities in the IT system AULA.

The supervision is a continuation of the Data Protection Authority's previous oversight of Kombit A/S (hereinafter referred to as KOMBIT) in December 2019, where the supervision during a site visit could ascertain that KOMBIT is not to be regarded as the data controller for AULA under Article 4, No. 7 of the General Data Protection Regulation.

Therefore, the Data Protection Authority informed KOMBIT that KOMBIT must ensure that all

municipalities are informed about their data responsibility and that KOMBIT transfers all necessary materials and information to the municipalities in this regard.

It is the Data Protection Authority's expectation that KOMBIT has informed the municipalities about this immediately after the site visit in December 2019.

2. Decision

After a comprehensive assessment, the Data Protection Authority finds that Esbjerg Municipality has not demonstrated that it has identified and assessed the most significant risks that the municipality's processing of personal data poses to the data subjects.

Furthermore, the Data Protection Authority finds that the overall documentation, including the risk assessment, is not sufficiently substantiated to demonstrate that Esbjerg Municipality has reduced the risk to a low level and ensured an appropriate level of protection concerning the risks to the data subjects that the processing of personal data in AULA entails.

On this basis, the Data Protection Authority finds that Esbjerg Municipality has not proven that the risk associated with the processing of personal data in AULA has been reduced to a low level. Thus, it is the Data Protection Authority's assessment that Esbjerg Municipality has not sufficiently demonstrated that it has ensured a security level that is appropriate to the risks posed by the processing of personal data in AULA.

The Data Protection Authority therefore criticizes that Esbjerg Municipality's processing of personal data has not been carried out in accordance with Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1 of the General Data Protection Regulation.

Furthermore, it is the Data Protection Authority's assessment that Esbjerg Municipality has not conducted a satisfactory impact assessment, pursuant to Article 35, paragraph 1 of the General Data Protection Regulation, as the submitted impact assessment does not meet the minimum requirements set out in Article 35, paragraph 7, letters a-d of the Regulation.

Additionally, the Data Protection Authority finds that Esbjerg Municipality, by first preparing an impact assessment for the processing of personal data in AULA 10 months after it became clear that the municipality is the data controller for the processing of personal data in a solution that entails a high risk for the data subjects, has acted in violation of Article 35, paragraph 1 of the General Data Protection Regulation.

On this basis, the Data Protection Authority further finds grounds to criticize that Esbjerg Municipality's processing of personal data has not been carried out in accordance with Article 35, paragraph 1 of the Regulation.

3. Case Presentation

The Data Protection Authority, by letter dated October 15, 2021, announced the supervision of Esbjerg Municipality. In this connection, the Data Protection Authority requested the municipality to submit the following:

- The risk assessments that form the basis for the evaluation of what security is considered appropriate for the processing of information about individuals in "AULA," as well as a description of the general security models in the application.
- To the extent that impact assessments have been prepared, copies of all versions of these.
- A review of considerations regarding the use of Article 25 of the General Data Protection Regulation in connection with the procurement and development of "AULA."
- A review of authorization and access control models.

Esbjerg Municipality submitted a statement regarding the case along with a number of appendices on November 3, 2021. Additionally, Esbjerg Municipality submitted further material on December 1, 2021, which was inadvertently not submitted together with the municipality's statement.

Based on the statements from the six selected municipalities, the Data Protection Authority has chosen to limit the focus of the supervision to the issues of risk assessment and impact assessment. It should be emphasized in this context that the Data Protection Authority has not, in connection with this supervision, taken a position on whether Esbjerg Municipality's processing of personal data in AULA is

in accordance with Article 25 of the General Data Protection Regulation regarding data protection by design and by default, or whether the municipality's authorization and access control models are in accordance with Article 32 of the General Data Protection Regulation.

The Data Protection Authority subsequently, by letter dated December 6, 2022, posed a number of clarifying questions to Esbjerg Municipality regarding any mitigating measures the municipality has taken. The municipality responded to these questions on December 12, 2022.

3.1. General Information on the Decision and Development of AULA

The Danish Municipalities' Association (hereinafter KL) states on their website that the municipal procurement of AULA is part of the User Portal Initiative, which is a political initiative from 2013.[3] It further states that AULA aims to support communication and thus collaboration regarding children's learning and well-being in a secure and user-friendly manner.

KL also states that all 98 municipalities in Denmark came together in 2016 for a joint tender for a collaboration platform – the later AULA – for the school sector. AULA was put out to tender by the municipalities' IT community, KOMBIT, at the beginning of 2017, and the choice fell on the supplier Netcompany – IT and...

****Business Consulting****, which has since developed AULA in collaboration with the companies Frog, EduLab, and Advice. KOMBIT informs about AULA on the website aulainfo.dk. It appears from this that the majority of public schools adopted AULA in 2019 and daycare services in the winter of 2020/2021.[4] The Data Protection Agency assumes that individual municipalities are independently responsible for their processing of personal data in AULA, and that KOMBIT, which is the data processor for the municipalities, has entered into a data processing agreement with Netcompany, which is thus a sub-processor.[5]

****3.2. Esbjerg Municipality's Comments****

****3.2.1. Risk Assessment****

Esbjerg Municipality has submitted six risk assessments and stated that these are risk assessments of the municipality's registers of processing activities. The Data Protection Agency understands from the material that the risk assessments relate to processing activities described in the municipality's register of processing activities according to Article 30 of the General Data Protection Regulation concerning the municipality's schools and daycare services. Three of the risk assessments appear to concern the processing of personal data in relation to the municipality's daycare services, while the other three risk assessments relate to the processing of personal data concerning the municipality's public schools. Furthermore, the Data Protection Agency understands from the material that these are risk assessments that generally concern the processing of personal data in relation to the municipality's public schools and daycare services. For each area, there is a risk assessment concerning confidentiality, integrity, and availability. The Data Protection Agency can ascertain that the municipality has assessed in the material that the identified risks are categorized as "low" or "very low."

In the risk assessment focusing on confidentiality regarding the processing of personal data in relation to the municipality's public schools, it is assessed that the consequence for the data subjects in the event of a breach of confidentiality constitutes a limited consequence, and that the vulnerability is categorized as "low/less likely," and thus the risk is low. A scenario is described where an employee accidentally sends information about a student to an incorrect recipient, and that this may involve ordinary, sensitive, and confidential personal data.

In the risk assessment, a subsequent evaluation of the consequence, vulnerability, and residual risk is made concerning questions about the likelihood that data subjects will be exposed to various categories of consequences. The following categories of consequences are involved: discrimination or differential treatment, economic consequences, identity theft or fraud, physical harm, mental/psychological harm, damage to material objects, and damage to reputation or other social consequences. The Data Protection Agency can ascertain that Esbjerg Municipality assesses that for all these categories of consequences, a breach of confidentiality results in a limited consequence, that the vulnerability is assessed to be low/less likely, and that the risk is very low.

Esbjerg Municipality has additionally stated that KOMBIT has conducted the risk assessments for AULA. In their response, Esbjerg Municipality has attached these risk assessments. Based on a sample review, the Data Protection Agency has found that the attached material from KOMBIT generally states that a number of processing activities carried out in AULA involve a high risk for the data subjects. It further appears from the material that it is expected/likely that a number of scenarios will occur, which involve consequences categorized as "devastating" or "very serious."

For example, it appears from the risk assessment for the messaging module in AULA that they have identified 10 threats, three of which are deemed most likely. The three threats are marked in red, and the Data Protection Agency understands from the material that KOMBIT assesses that these are high risks.

One of the threats concerns user behavior that leads to mishandling of personal data in the system, carried out by an authorized user through inadvertent disclosure of personal data in the application. The consequence of loss of confidentiality is categorized as "devastating," and it is stated, among other things, that children may suffer significant damage to their reputation, which can lead to social losses. The likelihood is categorized as "expected," and it is noted in this context that it is expected that there will be cases where a user mistakenly sends a message containing personal data to one or more users, for example, by sending to a group.

Another of the threats concerns inadvertent process errors that lead to incorrect handling due to incorrect or missing implementation of data classification in the solution. It is further described as a leak of sensitive data due to incorrect (too low) or missing data classification. The consequence of loss of confidentiality is categorized as "very serious." It is stated that the reason for this is that sensitive personal data (e.g., messages regarding a child's illness/health) can be accessed or altered by unauthorized individuals internally, and that data subjects are exposed internally to unauthorized individuals.

It is further stated that data subjects are exposed in a way that harms social relationships, both internally among colleagues/students. The likelihood is categorized as "expected." It is noted in this connection that it is users who must classify data and human errors are expected. As an example, it is stated that it is possible for a user to send a message containing sensitive personal data without marking it as "sensitive message," resulting in lower security.

The third threat concerns inadvertent process errors, where there are incorrect accesses due to missing or unclear policies. The consequence of loss of confidentiality is categorized as "very serious." The material provides the same description of the consequence as for incorrect handling due to incorrect or missing implementation of data classification in the solution. The likelihood is categorized as "expected." It is noted in this context that all municipalities must assign rights to many users/groups, which is why errors must be expected. For example, it is stated that a group may have members who no longer belong to the group and who have not been removed from the group. However, Esbjerg Municipality does not appear to have addressed what KOMBIT's risk assessment material has specifically prompted Esbjerg Municipality to consider as the data controller.

On this basis, the Data Protection Agency has asked Esbjerg Municipality to inform whether they have taken mitigating measures aimed at reducing the risk to the registered individuals. If Esbjerg Municipality has not taken mitigating measures, the Data Protection Agency has requested that Esbjerg Municipality inform the agency of the reasons for this.

Esbjerg Municipality has subsequently referred to the municipality's statement regarding their considerations in relation to the General Data Protection Regulation's Article 25, as well as authorization and access control models in their initial consultation response to the Data Protection Agency. It is stated, among other things, that "secure files" are not used in AULA in Esbjerg Municipality. Specific information about individual children is found in the system Hjernen&Hjertet, which employees have access to. Parents do not have access to Hjernen&Hjertet; but receive information via the Parent Portal in digital mail.

Esbjerg Municipality has also submitted their impact assessment, which was mistakenly not submitted earlier. It appears from the impact assessment that Esbjerg Municipality has identified 33 security controls that can reduce the risk and consequence for the registered individuals.

The conclusion of the impact assessment states that there is a high consequence for the registered individuals if a security breach were to occur. Furthermore, it is noted that the municipality has subsequently assessed which threats may pose a risk of security breaches and subsequently trigger the consequences for the registered individuals. The municipality has then identified 33 security controls that can reduce the risk and consequence for the registered individuals. Esbjerg Municipality has stated in the impact assessment that the implementation and ongoing work with security controls result in the general risk being assessed as low.

Esbjerg Municipality has assessed in the impact assessment that the risk has been reduced to a value of 4 (low) from a value of 25 (high) based on the threat and risk assessments as well as the security measures implemented. It is stated that the assessment criteria for this are "Sensitivity of the information," "Restricted freedom of action," and "The technology's potential to infringe privacy," which indicate the strength or intensity of a potential infringement for the registered individuals. The last two assessment criteria are "Identification potential" and "Size of the user group," which Esbjerg Municipality describes as having limited independent significance, but that they have the property of reinforcing the consequences of the breaches caused by the other three assessment criteria.

It appears from Esbjerg Municipality's impact assessment that the municipality has identified a number of threats related to the processing of personal data in AULA and has assessed how significant a risk they pose in relation to the registered individuals. Additionally, Esbjerg Municipality has listed a number of measures (controls) for each of the identified threats that are intended to reduce the risk. Finally, the municipality has assessed the risk after these measures.

Among other things, it appears from Esbjerg Municipality's impact assessment that unintentional information leakage has been identified as a threat in the processing of personal data in AULA. In this context, it is noted that it can have consequences for the confidentiality and integrity of the information, e.g., due to incorrect accesses resulting from missing or unclear policies, lack of follow-up on deletion procedures, data leaks due to lack of functional separation, incorrect handling due to incorrect or missing implementation of data classification in the solution, overly broad user rights/access privileges, and erroneous publication of data containing sensitive information. According to the description, the risk has been reduced from medium to low after implementing a number of security controls, including periodic reviews of access rights as well as policies and procedures to ensure data exchange across communication channels.

Another example of an identified threat described in Esbjerg Municipality's impact assessment is user error. It is noted in this context that it can have consequences for confidentiality and integrity, e.g., due to mishandling of personal data in the system/solution by an authorized user and unintentional user actions, mishandling of media, and lack of user training. According to the description, the risk has been reduced from medium to low after implementing a number of security controls, including logging of standard user activities, information security policy, guidelines for employees regarding and procedures for granting access rights that match the organization's security requirements for access to data.

There are two threats that Esbjerg Municipality assesses pose a high risk prior to the implementation of security measures (controls). One threat concerns attacks with malicious code, where it... it states that it may have consequences for confidentiality, integrity, and availability. The municipality assesses that the risk has been reduced to low. The second threat concerns cyberattacks, where it is indicated that it may have consequences for confidentiality and availability. The municipality assesses that the risk has been reduced to medium. The relevant impact assessment is discussed further in the section below.

3.2.2. Impact Assessment

Esbjerg Municipality has submitted the municipality's impact assessment regarding data protection concerning the processing activities in AULA and has stated that they have prepared the impact assessment based on KOMBIT's risk assessments. It is noted that the impact assessment was completed on October 26, 2020. The Data Protection Agency understands from the impact assessment that AULA has been in use at the municipality's public schools since September 2019 and at the municipality's daycare facilities and childminders since July 2020. This is based on the municipality's indication of how many individuals have access to AULA, with these dates specified.

The impact assessment is prepared in an Excel sheet with several tabs. The impact assessment contains the following:

On the page titled "Information about the Impact Assessment, cf. the Data Protection Regulation," there is general information about what an impact assessment is, why an impact assessment must be conducted, what Article 35, paragraph 1, first sentence of the Data Protection Regulation states, and who should conduct a risk assessment. Additionally, the page contains the following comment from Esbjerg Municipality's data protection advisor: "I assess that sufficient technical and organizational measures have been taken to reduce the risk for the data subject. I agree with the conclusions in this impact assessment." It is noted that the data protection advisor's assessment was made on October 30, 2020.

On the page titled "Table 1: Should an Impact Assessment be Prepared," there is information about the date of the table's completion (October 26, 2020). Furthermore, the page includes a description of what personal data is processed and the purpose of the processing, as well as an assessment of whether an impact assessment should be prepared.

On the page titled "Mapping of Processing Activities," the following is described: who is the data controller, types of personal data processed, the basis/legal grounds for processing personal data, categories of data subjects, number of data subjects, processing activities that data undergo throughout the entire process(es), type of technology used, staff groups that have access to data, number of individuals who have access to personal data, data exchange, data deletion, potential use of external data processors, potential disclosure of information to third parties.

On two pages titled "Consequences for the Data Subjects," assessments have been made based on the following criteria: "Sensitivity of the Information," "Restricted Freedom of Action," and "Technology's Potential to Infringe Privacy," where the municipality has assessed whether an infringement of privacy can have critical consequences, annoying consequences, or no or insignificant consequences. Esbjerg Municipality has assessed that, concerning all criteria, an infringement of privacy can have critical consequences.

Additionally, on these pages, Esbjerg Municipality has made an assessment based on the following criteria: "Identification Potential" and "Size of the User Group," where they have assessed whether the consequence of an infringement of privacy could be seriously aggravated, aggravated, or not affected. Regarding "Identification Potential," Esbjerg Municipality has assessed that an infringement of privacy could be seriously aggravated. Regarding "Size of the User Group," Esbjerg Municipality has assessed that the consequence of an infringement of privacy could be aggravated.

On the page titled "Consequences for the Data Controller," the impact on the data controller's reputation and the economic consequences of serious breaches of privacy have been assessed.

On the page titled "Impact Assessment – The Overall Impact Assessment for the Data Subject," an overall impact assessment for the data subjects has been made before the implemented controls (measures). It is noted that the assessment criteria for this are "Sensitivity of the Information," "Restricted Freedom of Action," and "Technology's Potential to Infringe Privacy," which indicate the strength or intensity of a potential infringement for the data subjects. The last two assessment criteria are "Identification Potential" and "Size of the User Group," which Esbjerg Municipality describes as having limited independent significance, but that they have the property of reinforcing the consequences of the breaches caused by the other three assessment criteria. The overall impact assessment for the data subject is therefore calculated to have a value of 25, which constitutes a high

risk.

On the page titled "Threats and Controls," a number of threats are listed with an indication of low, medium, or high. It is noted that this is a risk assessment based on the controls that are already in place in Esbjerg Municipality. Additionally, the page contains a column indicating any controls for the individual threats. An example of a control is "Action Plan for Awareness of Good Data Processing Practices." There is then a column titled "Risk After," where "low" is indicated for the majority of threats. "Medium" is indicated for the threats "Malware Attacks" and "Cyberattacks." Finally, the page contains a column with remarks for each threat. Here it is noted, among other things, whether it is a relevant threat. Regarding the threats identified as relevant, it is indicated whether it may have consequences for confidentiality, integrity, and/or availability. On the page titled "Security Controls," Esbjerg Municipality's 33 security controls are listed, indicating whether it is a relevant control, remarks on the specific security control, where the responsibility for the security control is located, and a reference with a link to any relevant material. On the page titled "Conclusion," it is described that the risk has been reduced from high to low. There is a reference to the page titled "Impact Assessment – The Overall Impact Assessment for the Data Subject," and the Data Protection Authority can deduce from that page that the risk has been assessed based on the assessment criteria described on that page. Additionally, five types of threats have been identified that the municipality has assessed could pose a risk of security breaches. It follows that to counter the threats that have been uncovered, a number of security controls have been established that together ensure the protection of the personal data involved in the use of AULA in Esbjerg Municipality. In this connection, it is stated that 33 security controls have been identified that can reduce the risk and consequences for the registered individuals. Finally, it is stated on the page that Esbjerg Municipality, based on the threat and risk assessments as well as the implemented security measures, assesses that the processing taking place will not result in a high risk for the registered individuals, and that the municipality, based on the impact analysis, assesses that it is not necessary to report the processing to the Data Protection Authority prior to commencement. The last page is titled "Calculations – Do Not Edit" and contains the numerical values that the Data Protection Authority assumes underlie Esbjerg Municipality's assessment that the risk has been reduced to 4 (low risk) from 25 (high risk).

3.3. Reported Breaches of Personal Data Security Regarding AULA

The background for the Data Protection Authority's initial decision to supervise municipalities with a particular focus on the technical and organizational security measures observed to meet the requirement for an appropriate level of security for the processing in AULA is that the authority has seen (and continues to see) a number of reported breaches of personal data security in connection with the processing of personal data in AULA. In AULA, personal data is processed, including confidential and sensitive personal data about vulnerable registered individuals, which includes children. Furthermore, the system's users are often individuals who do not primarily work with data protection (including educators, pedagogical staff, as well as students and parents), which, in the authority's opinion – in light of the many reported breaches from the vast majority of the country's municipalities – may imply that stricter requirements should be imposed on the data controllers' observance of both technical and organizational measures, cf. Article 32 and mitigating measures for compliance with the regulation's Article 25. A significant portion of these reports of breaches of personal data security in AULA concern that personal data has been sent to one or more incorrect recipients in AULA. For example, where a message or secure file about a child has been sent to another child's parents, or where a message has been mistakenly sent to a group of recipients instead of a specific recipient. The Data Protection Authority has also seen instances where, when sending documents to one or more parents, an incorrect document containing information about another child has been attached. Thus, there have been several unintended disclosures of personal data about children in AULA, including descriptions of children's concentration difficulties, referrals for pedagogical-psychological assessment, information about dyslexia, school reports, as well as action plans and assessments of educational readiness. By searching in the Data Protection Authority's ESDH system, the authority can ascertain that it has received 11 reports of breaches of personal data

security from Esbjerg Municipality under the Data Protection Regulation's Article 33, where AULA is mentioned in the report. Several of the reports concern unauthorized access to personal data. One of the reports concerns unauthorized access to information, as it has been indicated in contact lists and profiles whether contacts (parents) have parental authority over a child or not. Users of AULA, including children and parents, have thus had unauthorized access to this information. Another report concerns unauthorized access for users who were previously members of a group to new media that have been added to the album after the user left the group. Additionally, several of the breach reports concern that personal data has been sent to one or more incorrect recipients in AULA. There are both cases where a message containing confidential information about a student has been sent to another student's parents, and where a message has been sent to an entire parent group instead of the specific student's parents. There are also cases where incorrect files containing personal data about students have been attached to posts on AULA.

4. Justification for the Data Protection Authority's Decision

4.1. Risk Assessment

The Data Protection Authority, based on Esbjerg Municipality's own information in the case, assumes that the municipality has prepared its own risk assessments, which generally concern the municipality's processing of personal data in relation to the municipality's public schools and daycare services, which Esbjerg Municipality refers to as risk assessments in their records. In this context, the Data Protection Authority assumes that Esbjerg Municipality's risk assessments of processing activities described in the municipality's record of processing activities under Article 30. The General Data Protection Regulation in relation to the municipality's schools and daycare services constitutes general risk assessments for all processing activities carried out in relation to the municipality's public schools and daycare institutions, and that the assessment does not specifically address the risks associated with the processing of personal data in AULA. The Data Protection Authority further assumes that Esbjerg Municipality has endorsed the submitted risk assessments for AULA, which have been prepared by KOMBIT, and that Esbjerg Municipality has additionally conducted a risk assessment in their impact analysis regarding AULA, where a number of threats have been identified, and where Esbjerg Municipality has identified 33 security controls that they believe can reduce the risk from high to low. In this context, the Data Protection Authority assumes that Esbjerg Municipality's risk assessment in the submitted impact analysis constitutes the municipality's risk assessment for the processing activities carried out in AULA. The Data Protection Authority has thus based its review of Esbjerg Municipality's assessment of what security the municipality considers appropriate for the processing of personal data in AULA on this risk assessment. Furthermore, the Data Protection Authority has understood from Esbjerg Municipality's statements that the municipality does not use the "secure file sharing" module in AULA, and that documents containing information about children are therefore not shared with their parents via AULA. The Data Protection Authority has understood that this is based on considerations following the guidelines in Article 25, paragraph 1, of the General Data Protection Regulation regarding pseudonymization and data minimization. It is also stated in Esbjerg Municipality's impact analysis that "secure file sharing" is not used in Esbjerg Municipality, but that "secure file sharing" cannot be turned off. It further states that sensitive information may therefore occur in the "secure file sharing" module.

4.1.1. Relevant Rules

The General Data Protection Regulation requires, at several points, that a data controller addresses the risks to the rights and freedoms of data subjects and can document the considerations and conclusions this has led to. It follows directly from the provisions in Articles 5, paragraph 1, letter f, 24, 25, 32, 33, 34, 35, 36, and 39, that the data controller must address the risks to the rights and freedoms of data subjects. Furthermore, it follows from both Article 5, paragraph 2 regarding the principles in Article 5, paragraph 1, and Article 24 regarding compliance with the entire regulation, that a data controller must be able to demonstrate compliance with data protection rules. Among other things, Articles 25, 35, and 36 require that considerations regarding the involved risks to the rights of data subjects must take place before processing activities are initiated. It follows from Article 5,

paragraph 1, letter f, of the General Data Protection Regulation that personal data must be processed in a manner that ensures adequate security for the personal data in question, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures. The data controller must also be able to demonstrate that the fundamental principles are adhered to, which follows from Article 5, paragraph 2 of the General Data Protection Regulation. Article 32, paragraph 1, of the General Data Protection Regulation states that the data controller must take appropriate technical and organizational measures to ensure a level of security appropriate to the risks associated with the data controller's processing of personal data. It follows from Article 24, paragraph 1, of the General Data Protection Regulation that a data controller must implement appropriate technical and organizational measures to ensure and to be able to demonstrate that the processing is in compliance with the regulation.

The data controller has an obligation to identify the risks that the data controller's processing poses to the data subjects and to ensure that appropriate security measures are implemented to protect the data subjects from these risks. The data controller must also be able to demonstrate that personal data is processed in a manner that ensures adequate security for the individuals to whom the data relates. In order for the supervisory authority to assess whether an appropriate level of security has been ensured, it must therefore be documented and explained what risks the data controller has identified and what mitigating measures have been taken to reduce these risks.

4.1.2. General Requirements for Risk Assessment

The Data Protection Authority notes that it is not specified in the General Data Protection Regulation how detailed the risk assessment must be. It is the Data Protection Authority's opinion that the data controller must establish an appropriate level considering the risks that are relevant to the data controller's processing of personal data. If a supplier, data processor, or available analyses, etc., establishes or indicates specific risk scenarios, it is the Data Protection Authority's opinion that data controllers should take these assessments into account, especially when processing activities in a system are deemed to involve high risks for the data subjects. At a minimum, there must be a substantiated assessment of why the situation is not relevant in the processing of personal data that occurs with the data controller. It is not explicitly stated anywhere in the General Data Protection Regulation how the documentation should look, what the specific content should be, or what the frequency of updating and revising should be. The Data Protection Authority finds that the documentation obligation implies that the supervisory authority – out of the total...

material that the data controller may present – can make an assessment of whether the processing is in compliance with the General Data Protection Regulation.

It should thus be clear from the presented material how and on what basis the data protection considerations have been made. This is, among other things, in relation to the legality of the processing activities and the ability to ensure compliance with the rights of the data subjects, adherence to the data protection principles, and ensuring an appropriate level of security.

Furthermore, it should be clear what considerations, choices, and omissions have been made in order to ensure that the processing of the information is in compliance with the General Data Protection Regulation.

In this context, it should be possible to timestamp when and with what content relevant considerations and actions have taken place.

It is the opinion of the Data Protection Authority that a risk assessment should include an evaluation of the consequences (e.g., high, medium, low) for the data subjects in the event of loss of confidentiality, availability, and integrity. Subsequently, the risk assessment should identify which threats exist regarding the loss of

confidentiality, availability, and integrity, as well as the likelihood (e.g., high, medium, low) that the threat will materialize. Finally, the risk assessment should map the existing security measures and their contribution to reducing the risk. On this basis, the data controllers can assess the risk and determine whether it is an acceptable risk or whether additional measures should be implemented. By addressing these elements in a risk assessment, the data controllers can thus document how they have assessed the risk for the data subjects regarding the relevant processing activities, as well as on what basis they believe that the implemented measures have reduced the risk.

4.1.3. Esbjerg Municipality's identification and assessment of risks

The Data Protection Authority assumes that Esbjerg Municipality in their impact assessment has identified a number of threats and assessed the risk for each of these threats before and after a number of listed measures. However, the Data Protection Authority cannot deduce from the material how Esbjerg Municipality assesses the different risks, as the municipality has only indicated "high," "medium," or "low."

Esbjerg Municipality's risk assessment in their impact assessment does not contain the elements that, in the opinion of the Data Protection Authority, a risk assessment should include. Reference is made to section

4.1.2. above.

Furthermore, the Data Protection Authority assesses that Esbjerg Municipality does not concretely address what the risks entail in relation to the processing activities taking place in AULA concerning the described threats and risks in the impact assessment. For example, regarding the threat of "User Error," it is generally described that it may have consequences for confidentiality and integrity. As an example, it is mentioned that mishandling of personal data in the system/solution by an authorized user may occur. However, it is not clear how an authorized user's mishandling of personal data in AULA can affect the confidentiality and integrity of the information, what consequences it may have for the data subjects, or what the likelihood is that the threat will materialize.

Esbjerg Municipality also does not address in their risk assessment in the impact assessment the risk that Esbjerg Municipality does not use the "secure file sharing" module, but that "secure file sharing" cannot be turned off, and that sensitive personal data may therefore occur in the module.

Furthermore, the Data Protection Authority can ascertain by comparing Esbjerg Municipality's impact assessment with the submitted material from KOMBIT that Esbjerg Municipality, in their identification of risks before any measures have been taken, has assessed some

risks as medium, while KOMBIT has assessed these risks as high. For example, the Data Protection Authority can mention incorrect accesses due to lacking or unclear policies and mishandling of personal data in the system/solution, conducted by an authorized user.

Esbjerg Municipality has assessed that the risk in relation to these risks has been reduced to low.

However, Esbjerg Municipality does not appear to have explained why the stated risk scenarios entail a lower risk in Esbjerg Municipality than what is indicated in KOMBIT's risk assessment.

On this basis, the Data Protection Authority finds that Esbjerg Municipality has not demonstrated that they have identified and assessed the most significant risks that the municipality's processing of personal data poses to the data subjects.

4.1.4. Esbjerg Municipality's description of measures

The Data Protection Authority understands from the information in the impact assessment that Esbjerg Municipality has made a comprehensive assessment of the risk for the data subjects – which has been reduced from high to low – based on the following assessment criteria: "Sensitivity of the information," "Restricted freedom of action," "Technology's potential to infringe privacy,"

"Identification potential," and "Size of the user group." However, the Data Protection Authority cannot deduce from the material what the basis is for the overall risk being assessed as low after the implemented measures.

It is also not clearly stated how the listed measures are relevant in relation to reducing the identified threats. For example, the Data Protection Authority can mention that regarding the threat of unintended information leakage, "Guidelines/processes for informing about the purpose of data processing, and this occurs at the data collection point" is mentioned as a measure. The Danish Data Protection Agency can also ascertain that it is not evident from the impact assessment how the measures have reduced the various risks. In this context, the Agency notes, as mentioned above under point 4.1.3, that it cannot deduce from the material how Esbjerg Municipality assesses the various risks before and after the implemented measures, as the municipality has merely indicated "high," "medium," or "low." The Data Protection Agency finds that the overall documentation, including the risk assessment, is not sufficiently substantiated to demonstrate that Esbjerg Municipality has reduced the risk to a low level and ensured an appropriate level of protection concerning the risks to the data subjects that the processing of personal data in AULA entails.

4.1.5. Specifically regarding the risk of erroneous sending in AULA's messaging module

It is generally the Data Protection Agency's view that data controllers who systematically use a technical functionality to send messages containing confidential and/or sensitive information should, in the Agency's opinion, investigate whether it is possible to implement one or more technical measures to reduce the risk of erroneous sending, or whether it is possible to design the messaging function in a way that minimizes such risk.

On this basis, the Data Protection Agency recommends that Esbjerg Municipality, together with KOMBIT and the other data-controlling municipalities, conduct such an investigation. This is particularly relevant considering that AULA's users are often individuals who do not primarily work with data protection (teachers, educational staff, and parents), which, in the Agency's opinion—given the many reported breaches—may imply that stricter requirements should be imposed on the data

controller's observance of both technical and organizational measures pursuant to Article 32. In this context, the Data Protection Agency can mention that it has found that AULA's messaging module is designed in such a way that in messages sent to multiple recipients, it is most obvious to reply to all persons in the message thread. There is a less visible field where it is possible to reply directly to the sender of the message. However, in the field where the user replies to all in the message thread, there is information about how many persons the user is replying to. Such a design of the messaging function, in the Data Protection Agency's opinion, entails a risk that users of AULA inadvertently send a message to all recipients in a message thread instead of solely to the sender of the message. In this context, there is a risk that sensitive or confidential personal data is unlawfully disclosed to incorrect recipients.

Furthermore, the Data Protection Agency has found that recipient suggestions are automatically generated when the user begins to type in the recipient field "To." In this context, both employees, children, and parents are suggested as recipients. This, in the Data Protection Agency's opinion, entails a risk that users select one or more incorrect recipients from the list of suggested recipients, or that they select, for example, all suggested parents whose first name or last name contains the entered letters, instead of one specific recipient.

4.1.6. Overall assessment regarding risk assessment

After an overall assessment, the Data Protection Agency finds that Esbjerg Municipality has not demonstrated that it has identified and assessed the most significant risks that the municipality's processing of personal data poses to the data subjects.

The Data Protection Agency further finds that the overall documentation, including the risk assessment, is not sufficiently substantiated to demonstrate that Esbjerg Municipality has reduced the risk to a low level and ensured an appropriate level of protection concerning the risks to the data subjects that the processing of personal data in AULA entails.

On this basis, the Data Protection Agency finds that Esbjerg Municipality has not proven that the risk associated with the processing of personal data in AULA has been reduced to a low level. It is thus the Data Protection Agency's assessment that Esbjerg Municipality has not sufficiently demonstrated that it has ensured a security level that is appropriate to the risks that the processing of personal data in AULA entails.

The Data Protection Agency therefore criticizes that Esbjerg Municipality's processing of personal data has not been carried out in accordance with the General Data Protection Regulation's Article 5, paragraph 2, cf. paragraph 1, letter f, and Article 24, paragraph 1, cf. Article 32, paragraph 1.

In choosing a reaction, the Data Protection Agency has emphasized that Esbjerg Municipality does not appear to have documented how it has assessed the risk to the data subjects from the relevant processing activities, as well as on what basis it assesses that the implemented measures have reduced the risk.

The Data Protection Agency has also emphasized that Esbjerg Municipality has not—where it deviates from KOMBIT's assessment of risks—explained why the stated risk scenarios entail a lower risk in Esbjerg Municipality than what is indicated in KOMBIT's risk assessment.

The Data Protection Agency should note in this context that it continues to regularly receive reports of breaches of personal data security in AULA from municipalities across the country, including incidents where information is inadvertently disclosed to unauthorized parties in, for example, messages. As mentioned above under point 3.3, the Data Protection Agency can ascertain that these incidents can have serious consequences for the affected data subjects. It is thus on this basis—and after a review of KOMBIT's risk assessment and Esbjerg Municipality's risk assessment in their impact analysis—that the Data Protection Agency's assessment is that the risk to the rights and freedoms of the data subjects has not been reduced to a low level.

4.2. Impact Assessment

4.2.1. Requirement for Impact Assessment

the municipalities that there has been uncertainty regarding where the data responsibility for the processing of personal data in the solution is located. Both the municipalities and KOMBIT have thus been of the opinion that the data responsibility for the processing of personal data in AULA – and

thereby also the responsibility for conducting risk assessments and impact analyses – was placed with KOMBIT.

4.2.3. Conclusion on the need for a Data Protection Impact Assessment (DPIA)

Based on the above, the Danish Data Protection Agency agrees with Esbjerg Municipality's assessment that the processing of personal data in AULA involves a high risk to the rights and freedoms of individuals. The Agency therefore finds that the processing activities carried out in AULA are subject to the requirement for a Data Protection Impact Assessment prior to the implementation of AULA.

4.3. The role of the Data Protection Officer (DPO)

According to Article 37 of the General Data Protection Regulation, a data controller is required to appoint a Data Protection Officer (DPO) when the processing is carried out by a public authority or body, or when the core activities of the controller or processor consist of processing operations which require regular and systematic monitoring of data subjects on a large scale, or of special categories of data.

The Danish Data Protection Agency notes that Esbjerg Municipality has appointed a DPO in accordance with the requirements of the GDPR. The DPO plays a crucial role in ensuring compliance with data protection legislation and should be involved in the development and implementation of AULA, particularly in relation to conducting the necessary impact assessments and ensuring that appropriate measures are in place to mitigate identified risks.

4.4. Recommendations

The Danish Data Protection Agency recommends that Esbjerg Municipality, in collaboration with KOMBIT, ensures that a comprehensive Data Protection Impact Assessment is conducted prior to the continued use and further development of AULA. This assessment should address the identified risks and outline measures to mitigate these risks effectively. Additionally, the DPO should be actively involved in this process to ensure compliance with data protection regulations.

5. Final remarks

The Danish Data Protection Agency emphasizes the importance of safeguarding personal data, especially when it concerns vulnerable individuals such as children. It is crucial that all necessary precautions are taken to protect their rights and freedoms in the context of AULA. The Agency will continue to monitor the situation and provide guidance as needed to ensure compliance with the General Data Protection Regulation.

KOMBIT, that KOMBIT is not to be regarded as a data controller, and therefore the Danish Data Protection Agency has informed KOMBIT that KOMBIT must ensure that all municipalities are informed of their data responsibility, and that KOMBIT must transfer all necessary materials and information to the municipalities in this regard.

The Data Protection Agency assumes that this ambiguity regarding data responsibility has been a reason why Esbjerg Municipality's impact assessment was not prepared prior to their processing of personal data in AULA. In this context, the Data Protection Agency assumes that Esbjerg Municipality, upon the implementation of AULA, believed that KOMBIT was the data controller for the processing of personal data in the solution and thus also responsible for the preparation of a risk assessment and impact analysis.

Based on the Data Protection Agency's supervisory visit to KOMBIT in December 2019 and the materials submitted by KOMBIT in this connection, the Data Protection Agency assumes that KOMBIT, in connection with the development of AULA – and before it was established that the municipalities were data controllers – conducted assessments of the risks and consequences for the data subjects from the processing of personal data in AULA, which show that the processing involves a high risk for the data subjects.

It is thus the Data Protection Agency's opinion that Esbjerg Municipality – like the other municipalities – should have recognized the high risk associated with the processing of personal data in AULA in

connection with KOMBIT informing the municipalities of their data responsibility regarding the processing of personal data in AULA and having transferred all necessary materials in this regard. It is the Data Protection Agency's expectation that KOMBIT informed the municipalities of this immediately after the supervisory visit in December 2019.

However, the Data Protection Agency can ascertain that Esbjerg Municipality is only seen to have prepared an impact analysis in October 2020, thus 10 months after there was clarity regarding the data responsibility for AULA.

It is the Data Protection Agency's opinion that Esbjerg Municipality, upon the determination of the municipality's data responsibility for the processing of personal data in AULA and the high risk that the processing entails, should have commenced the preparation of an impact analysis. The Data Protection Agency has particularly taken into account in its assessment that the purpose of an impact analysis is to determine the specific risks associated with the processing for the rights and freedoms of the data subjects and subsequently ensure that measures are established to mitigate these risks and reduce the risk to a level that is less than high before the processing begins.

On this basis, the Data Protection Agency finds that Esbjerg Municipality, by only having prepared an impact analysis for the processing of personal data in AULA 10 months after the municipality became aware that they are the data controller for the processing of personal data in a solution that entails a high risk for the data subjects, has acted in violation of Article 35, paragraph 1 of the General Data Protection Regulation.

4.2.3. Minimum Requirements for Impact Analyses

Article 35 of the General Data Protection Regulation contains a number of requirements that an impact analysis must meet at a minimum. These requirements follow from paragraph 7 and include the following:

- a systematic description of the planned processing activities and the purposes of the processing, including, where applicable, the legitimate interests pursued by the data controller
- an assessment of whether the processing activities are necessary and proportionate to the purposes
- an assessment of the risks to the rights and freedoms of the data subjects as referred to in paragraph 1, and
- the measures that are envisaged to address these risks, including safeguards, security measures, and mechanisms that can ensure the protection of personal data and demonstrate compliance with this regulation, taking into account the rights and legitimate interests of the data subjects and other affected persons.

The rules of the General Data Protection Regulation regarding impact analysis are intended to ensure that no processing, where there is an inherent high risk to the rights and freedoms of the data subjects, is initiated without the data controller having worked with and mitigated such risks.

An impact analysis regarding data protection is thus a tool that enables the data controller to systematically address the risks that a processing activity may entail.

The General Data Protection Regulation provides data controllers with the flexibility to determine the exact structure and form of the impact analysis regarding data protection. However, regardless of the form, an impact analysis regarding data protection must include the above minimum requirements and thus be a proper assessment of risks that enables the data controllers to take measures to mitigate them.

The Data Protection Agency has reviewed Esbjerg Municipality's impact analysis in relation to the minimum requirements in Article 35, paragraph 7 of the General Data Protection Regulation.

It is the Agency's overall assessment that Esbjerg Municipality has not conducted a satisfactory impact analysis, according to Article 35, paragraph 1 of the General Data Protection Regulation, as the submitted impact analysis does not meet the minimum requirements, according to Article 35, paragraph 7, letters a-d of the Regulation. The impact analysis does not, among other things, contain assessments of necessity and proportionality.

Below follows the Data Protection Agency's assessment of the impact analysis in relation to the individual minimum requirements that follow from Article 35, paragraph 7, letters a-d.

Ad a) Systematic description of processing activities and purposes

It is the opinion of the Data Protection Agency that the requirement for a systematic description of the planned processing activities and the purposes of the processing pursuant to Article 35, paragraph 7, letter a of the Data Protection Regulation entails that the data controllers must provide a systematic description of the various forms of processing, e.g., collection, registration, disclosure, etc., that personal data will be subject to, as well as a clear description and definition of the personal data being processed. Furthermore, the requirement implies that the impact assessment must include a description of the purpose of the processing.

Additionally, it is the opinion of the Data Protection Agency that a systematic description should include information about the legal basis for the processing (authority), which categories of data subjects the information pertains to, the number of data subjects, information about where the data comes from, who—within and outside the organization—can access the data, how long the data is stored, whether there is a transfer of data to third countries (and on what basis), and whether new technologies are used for the processing of personal data.

Thus, the systematic description should contribute to the data controller's assessment of the specific likelihood and severity of high risks, taking into account the nature, scope, context, and purposes of the processing as well as the sources of risk. In this context, the Data Protection Agency refers to recital 90[7].

Esbjerg Municipality's impact assessment contains information about the various forms of processing activities that personal data undergoes in AULA, the legal basis for the processing, categories of data subjects whose information is processed in AULA, the number of registered individuals, the type of technology used, which staff groups have access to the data, the number of individuals who have access to the data, data storage, including when information in the "secure file sharing" module is deleted, the possibility of handling requests for deletion, the use of data processors, and the disclosure of information to third parties.

Esbjerg Municipality's impact assessment also includes an indication of the types of personal data processed in AULA. It is stated that both ordinary and sensitive personal data as well as CPR numbers are processed in AULA. It is further specified which contact information is processed. It is also indicated that Esbjerg Municipality chooses, based on need, which additional data about the student is necessary to know, and that this is reported as supplementary master data.

Regarding the special categories of personal data (sensitive personal data), Esbjerg Municipality indicates that institutions can choose to report information about, among other things, allergies. Furthermore, it is stated that sensitive personal data will occur in messages in AULA. Likewise, it is indicated in the impact assessment that sensitive personal data may occur in the "secure file sharing" module. It is noted in this context that "secure file sharing" is not used in Esbjerg Municipality, but that the module cannot be turned off. It is not specified which sensitive personal data, e.g., health information or information about religious beliefs, may be contained in messages and the "secure file sharing" module.

It is the understanding of the Data Protection Agency that it is the users of AULA, including parents and students, who use these modules in their communication with schools or daycare institutions, and therefore the municipality cannot necessarily predict exactly which examples of sensitive personal data the modules will contain.

However, it is the opinion of the Data Protection Agency that Esbjerg Municipality, in their description of the processing activities, can base it on their experiences regarding which types of information messages from educational staff, etc., to parents and students typically contain. Especially since AULA was implemented during Esbjerg Municipality's preparation of the impact assessment, it is the opinion of the Data Protection Agency that it has been possible for Esbjerg Municipality to describe in more detail which sensitive information is processed in AULA.

Furthermore, the impact assessment does not appear to contain information about how long the data is stored in relation to the other modules in AULA (beyond "secure file sharing"), or whether there is a transfer of personal data to third countries. However, it is noted that Esbjerg Municipality uses KOMBIT, Netcompany, and AWS (Amazon Web Services) as (sub)data processors, and that no employees at either KOMBIT or AWS have access to the solution, and that only selected employees at Netcompany have access for necessary troubleshooting and support.

However, it is the opinion of the Data Protection Agency that the impact assessment should indicate whether there is a transfer of personal data to third countries, as well as specify how long personal data processed in the solution is stored.

The Data Protection Agency can confirm that Esbjerg Municipality has described the purpose of the processing in the impact assessment. It is stated that the purpose of processing personal data in AULA is to provide a communication platform, thereby granting access to the processing and storage of data for daily work concerning children in daycare and students in the municipality's schools in a system that can support communication and learning processes in public schools and in the daycare sector. Furthermore, it is stated that there are no cases, decisions, profiling, personnel administration, etc., taking place in AULA.

On this basis, it is the assessment of the Data Protection Agency that Esbjerg Municipality has described their processing activities in AULA and the purpose of the processing, but that the description is not sufficiently detailed, as it does not contain information about what types of sensitive personal data are being processed, how long the personal data is stored, or a clear indication of whether there is a transfer of personal data to third countries. The minimum requirement in Article 35, paragraph 7, letter a is thus not met.

Ad b) Assessment of Necessity and Proportionality

The Data Protection Authority can ascertain that Esbjerg Municipality's impact assessment does not contain an evaluation of whether the processing activities are necessary and proportionate to the purposes, which is a requirement under Article 35, paragraph 7, letter b.

Ad c) and d) Assessment of Risks and Measures

Esbjerg Municipality's impact assessment includes an evaluation of the risks to the rights and freedoms of the data subjects, as well as a listing of the measures that the municipality assesses can reduce the risk to the data subjects. Esbjerg Municipality appears to have worked with the risks that the processing of personal data in AULA entails.

However, as stated above under point 4.1.6, it is the Data Protection Authority's assessment that Esbjerg Municipality has not demonstrated that the risk has been reduced to a low level, and that Esbjerg Municipality has thus not shown that they have ensured a level of security that is appropriate to the risks posed by the processing of personal data in AULA. The Data Protection Authority finds, after a comprehensive review of the submitted material, that the overall documentation, including the risk assessment in the impact analysis, is not sufficiently substantiated to demonstrate that Esbjerg Municipality has ensured an appropriate level of protection in relation to the risks for the data subjects posed by the processing of personal data in AULA.

It is therefore the Data Protection Authority's assessment that the content of the impact assessment regarding the municipality's evaluation of the risks and the listed measures (controls) is not sufficient to meet the minimum requirements in Article 35, paragraph 7, letters c and d.

4.2.4. Requirement to Consult the Data Protection Officer

It follows from the Data Protection Regulation's Article 35, paragraph 2, that the data controller must consult the data protection officer, if one has been appointed, when conducting an impact assessment regarding data protection. Furthermore, it follows from the Regulation's Article 39, paragraph 1, letter c, that the data protection officer must, at a minimum, advise, upon request, regarding the impact assessment concerning data protection and monitor its compliance in accordance with Article 35.

The Data Protection Authority assumes that Esbjerg Municipality has consulted the municipality's data protection officer, as it appears under the heading "Comment from DPO" in the impact assessment that the relevant DPO assesses that sufficient technical and organizational measures have been taken

to reduce the risk to the data subject. Additionally, it is stated that the data protection officer agrees with the conclusions of the impact assessment.

4.2.5. Overall Assessment Regarding the Impact Assessment

After reviewing Esbjerg Municipality's impact assessment, the Data Protection Authority finds that Esbjerg Municipality has not conducted a satisfactory impact assessment, pursuant to the Data Protection Regulation's Article 35, paragraph 1, as the submitted impact assessment does not meet the minimum requirements set forth in the Regulation's Article 35, paragraph 7, letters a-d.

The Data Protection Authority further finds that Esbjerg Municipality, by first preparing an impact assessment for the processing of personal data in AULA 10 months after it became clear that the municipality is the data controller for the processing of personal data in a solution that entails a high risk for the data subjects, has acted in violation of the Data Protection Regulation's Article 35, paragraph 1.

On this basis, the Data Protection Authority finds grounds to express criticism that Esbjerg Municipality's processing of personal data has not occurred in accordance with the Regulation's Article 35, paragraph 1.

In choosing a reaction, the Data Protection Authority has emphasized that Esbjerg Municipality has prepared an impact assessment for the processing of personal data in AULA that contains elements outlined in Article 35, paragraph 7, letters a, c, and d, but that the impact assessment does not contain an evaluation of whether the processing activities are necessary and proportionate to the purposes. Esbjerg Municipality's impact assessment is, in the opinion of the Data Protection Authority, also not sufficiently detailed. In this regard, the Data Protection Authority notes that the impact assessment does not contain an evaluation of whether the processing activities are necessary and proportionate to the purposes, and that the description of the processing activities is not sufficiently detailed. In this context, the Data Protection Authority notes that a systematic description of the processing activities should contribute to the data controller's assessment of the specific likelihood and severity of the high risks, taking into account the nature, scope, context, and purposes of the processing, as well as the sources of risk. Furthermore, the content of the impact assessment regarding the municipality's evaluation of the risks and the listed measures (controls) is not sufficient to meet the minimum requirements in Article 35, paragraph 7, letters c and d.

The Data Protection Authority has also emphasized the timing of Esbjerg Municipality's preparation of the impact assessment.

The Data Protection Authority notes in this context that the purpose of an impact assessment is to determine the specific risks posed by the processing to the rights and freedoms of the data subjects and subsequently...

ensure that measures are established to mitigate these risks and reduce the risk to a level that is less than high before the processing begins. The Data Protection Authority believes that Esbjerg Municipality should have commenced the preparation of a impact assessment upon recognizing the municipality's data responsibility for the processing of personal data in AULA and the high risk that the processing entails.

4.3. Summary

On the basis of the above, the Data Protection Authority finds grounds to express criticism that Esbjerg Municipality's processing of personal data has not been carried out in accordance with the General Data Protection Regulation (GDPR) Article 5, paragraph 2, in conjunction with paragraph 1, letter f, and Article 24, paragraph 1, in conjunction with Article 32, paragraph 1.

The Data Protection Authority further finds grounds to express criticism that Esbjerg Municipality's processing of personal data has not been carried out in accordance with the Regulation's Article 35, paragraph 1.

4.4. General Remarks from the Data Protection Authority

In system landscapes where multiple data controllers use the same systems and perform approximately the same processing of personal data, there can be significant synergy in conducting joint assessments regarding risk factors, potential impact assessments, and mitigating measures. The

Data Protection Authority notes that it may be relevant to conduct a joint impact assessment if several data controllers are planning to implement a common IT system or processing platform, for example, within the municipal sector. For multiple data controllers to collaborate on preparing a joint impact assessment, it is a prerequisite that the same type of system is involved, the same processing activity of the same personal data is performed, and that the processing activities entail similar high risks. It is not crucial that there is full identity between the systems and processing activities, but that the system, data, and particularly the processing activities do not deviate significantly from each other. Otherwise, a supplement to the joint impact assessment must necessarily be prepared.

Thus, the Data Protection Authority believes that it would be sufficient for several municipalities to prepare one impact assessment regarding data protection for the processing of personal data in the same system, provided by the same supplier, if the same processing activities are performed in the system, the same types of personal data are processed, and the processing activities entail the same high risks.

It is the data controllers who specifically assess whether a joint impact assessment can be conducted for the processing activities in the systems. The data controllers in a joint impact assessment are each responsible for carrying out the impact assessment.

The Data Protection Authority believes that regarding the municipalities' processing of personal data in AULA, the municipalities use the same type of system for the same processing activities of the same personal data, and that the municipalities' processing activities entail similar high risks. Furthermore, the system is provided by the same supplier. The municipalities thus have the opportunity to prepare a joint impact assessment regarding data protection for their processing of personal data in AULA.

In associations and bodies representing categories of data controllers, it may also be beneficial to develop a code of conduct in accordance with GDPR Article 40 to specify the application of the GDPR. A code of conduct can provide correct and practical guidance on how to organize oneself in connection with one or more processing activities to comply with data protection rules. This may include establishing procedures to be followed for a specific processing activity. A code of conduct will therefore be a useful tool to help comply with data protection rules for the authorities that have subscribed to the code. This facilitates compliance with the rules but does not relieve the individual data controller of the obligations and tasks that fall upon them as data controllers. This is particularly significant in situations where the data controller chooses to deviate from the assumptions in the common concepts and processing, for example, by using a system for other purposes.

On this basis, the Data Protection Authority encourages consideration across municipalities and possibly in collaboration with KL and KOMBIT to develop a code of conduct in accordance with GDPR Article 40 regarding the municipalities' processing of personal data in AULA. This may also be relevant to consider in relation to other processing activities in the municipalities, where the municipalities use the same system to process the same types of personal data for the same purposes.

[1] Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

[2] Act No. 502 of May 23, 2018, on supplementary provisions to the regulation on the protection of natural persons in relation to the processing of personal data and on the free movement of such data (Data Protection Act).

[3] KL has described the User Portal Initiative on their website: <https://www.kl.dk/kommunale-opgaver/boern-og-unge/digitalisering-paa-boerne-og-ungeomraadet/brugerportalsinitiativet/>

[4] KOMBIT provides information about AULA on the website.

[5] It appears from the material on the User Portal Initiative, which is available on KL's website: <https://www.kl.dk/media/11560/illustration-af-aftaler-om-databehandling-i-og-omkring-bpi.pdf>

[6] Guidelines for the Data Protection Impact Assessment (DPIA) and determining whether the processing "likely results in a high risk" under Regulation (EU) 2016/679, WP248 rev. 01, adopted on April 4, 2017, as last revised and adopted on October 4, 2017.

[7] From recital 90, it is stated: "In such cases, the data controller should carry out a data protection

impact assessment prior to the processing in order to assess the specific likelihood and severity of the high risks, taking into account the nature, scope, context, and purposes of the processing as well as the sources of risk. The impact assessment should particularly include the measures, safeguards, and mechanisms that are planned to mitigate this risk, to ensure the protection of personal data, and to demonstrate compliance with this regulation."

[8] Reference is made to the Danish Data Protection Authority's guidance on impact assessments from March 2018.